HUM 4747: Legal Issues and Cyber Law

Cyber Espionage, Surveillance & Privacy: The Pegasus Case Study

Aashnan Rahman

BSc in SWE
Islamic University of Technology (IUT)

Winter 2024-2025

Outline

What is Cyber Espionage?

Definition

The use of computer networks to gain **illicit access** to **confidential information**, typically held by a government or organization. It steals **classified, sensitive data or intellectual property** to gain an advantage over a competitive entity.

Types of Targets:

- Government secrets and military intelligence
- Corporate trade secrets and IP
- Political dissidents and journalists
- Human rights activists
- Critical infrastructure

Common Actors:

- **Nation-states** (state-sponsored hacking)
- Intelligence agencies
- Corporate espionage groups
- Private surveillance companies
- Advanced Persistent Threat (APT) groups

Cyber Espionage vs. Other Cyber Threats

Threat	Goal	Actor	Example
Cyber Espionage	Intelligence gathering	Nation-states, corporations	Pegasus spyware
Cyber Warfare	Disruption / destruction	Nation-states	Stuxnet (Iran nuclear)
Cybercrime	Financial gain	Criminal groups	Ransomware (WannaCry)
Hacktivism	Political / social message	Activist groups	Anonymous DDoS attacks
Cyber Terrorism	Cause fear / harm	Terrorist organizations	Infrastructure attacks

Key Distinction

Cyber espionage is often **silent and long-term**. The victim may never know their data was stolen — unlike ransomware or DDoS which are immediately visible.

The Surveillance Industry

A Growing Market

A multibillion-dollar industry of **private companies** sells surveillance tools to governments worldwide. These tools are marketed for **“legitimate law enforcement”** but are routinely abused.

Major Players:

- **NSO Group** (Israel) — Pegasus spyware
- **FinFisher / Gamma Group** (Germany/UK) — FinSpy
- **Hacking Team** (Italy) — Remote Control System (RCS)
- **Candiru** (Israel) — Windows and browser exploits
- **Cytrox** (North Macedonia) — Predator spyware

*These companies sell to governments, but the targets are often **journalists, lawyers, activists, and political opponents**.*

What is Pegasus?

Overview

Pegasus is a mobile phone spyware suite produced by Israeli "Cyber Warfare" vendor **NSO Group**. It is sold exclusively to government agencies for surveillance operations.

Capabilities — Once installed, Pegasus can:

- Access **passwords, contact lists, calendar events**
- Read **text messages** and **emails**
- Intercept **live voice calls** from messaging apps (WhatsApp, Signal, Telegram)
- Turn on the phone's **camera and microphone** remotely
- Track **GPS location** in real-time
- Extract data from **cloud services** (iCloud, Google Drive)

Complete Surveillance

Pegasus provides **total access** to a target's digital life — essentially turning their phone into a 24/7 surveillance device.

How Pegasus Works — Technical Overview

1. **Infection Vector**: Target receives or is exposed to a specially crafted **exploit link**
2. **Zero-Day Exploits**: A chain of **previously unknown vulnerabilities** is used to penetrate phone security
3. **Silent Installation**: Pegasus installs **without user knowledge or permission**
4. **C&C Communication**: Phone begins contacting operator's **Command & Control (C&C)** servers
5. **Data Exfiltration**: Private data is sent to the operator
6. **Remote Control**: Operator can execute commands — activate camera, microphone, etc.

Evolution of Infection Methods

- **2016**: Required target to **click a link** (SMS-based)
- **2019+**: **Zero-click** exploits — no user interaction needed (e.g., via WhatsApp call or iMessage)

Pegasus Infrastructure

How Operators Stay Hidden

- Exploit links and C&C servers use **HTTPS** (requires domain names)
- Domain names often **impersonate** legitimate services:
  - Mobile providers, banks, government services, news sites
- **Front-end servers**: Cloud-based VPS that forward traffic through proxy chains
- **Back-end servers**: Located on the operator's premises

Politically-Themed Domains Found

- `universopolitico.net`, `animal-politico.com` (Mexico)
- `politiques-infos.info`, `nouveau-president.com` (Togo)
- `revolution-news.co` (Morocco)

These suggest **politically motivated targeting** — not "legitimate" crime investigation.

The Citizen Lab — Who Are They?

About

An **interdisciplinary research lab** at the **Munk School of Global Affairs, University of Toronto**. Focuses on:

- Investigating **digital espionage** against civil society
- Documenting **Internet filtering** and surveillance technologies
- Analyzing **privacy and security** of popular applications
- Examining transparency between **corporations and state agencies**

Methodology: "Mixed Methods" approach

- Political science + Law + **Computer science** + Area studies
- Internet scanning, reverse engineering, DNS analysis

Key Findings — Pegasus in 45 Countries

Citizen Lab Report #113 (September 2018):

By the Numbers

- Scanned Internet: Aug 2016 – Aug 2018
- Found **1,091 IP addresses** matching Pegasus fingerprint
- Identified **1,014 domain names** pointing to those IPs
- Grouped into **36 distinct Pegasus operators** (each run separately)
- Detected suspected infections in **45 countries**
- At least **10 operators** engaged in **cross-border surveillance**

Countries with Known Abuse

At least 6 countries with significant Pegasus operations were previously linked to **abusive targeting of civil society**: Bahrain, Kazakhstan, Mexico, Morocco, Saudi Arabia, and the UAE.

Infected Countries

45 countries with suspected Pegasus infections:

Algeria, Bahrain, **Bangladesh**, Brazil, Canada, Cote d'Ivoire, Egypt, France, Greece, India, Iraq, Israel, Jordan, Kazakhstan, Kenya, Kuwait, Kyrgyzstan, Latvia, Lebanon, Libya, Mexico, Morocco, the Netherlands, Oman, Pakistan, Palestine, Poland, Qatar, Rwanda, Saudi Arabia, Singapore, South Africa, Switzerland, Tajikistan, Thailand, Togo, Tunisia, Turkey, the UAE, Uganda, the United Kingdom, the United States, Uzbekistan, Yemen, and Zambia.

Note

Bangladesh is on this list. This means Pegasus surveillance infrastructure was detected targeting or operating within Bangladesh.

How Citizen Lab Tracked Pegasus

Research Methodology:

1. **Fingerprinting (2016)**: Identified Pegasus servers by their "decoy pages" — fake websites shown to non-targets
2. **Fingerprinting (2017–18)**: NSO removed decoy pages; Citizen Lab developed new **TLS fingerprints** (ξ_1, ξ_2, ξ_3) and a clustering technique called **Athena**
3. **DNS Cache Probing**: Probed tens of thousands of ISP DNS caches worldwide to find which countries had devices looking up Pegasus domain names
4. **Clustering**: Grouped 1,091 IPs into **36 distinct operators** based on infrastructure patterns

Cat-and-Mouse Game

After Citizen Lab's 2016 report, NSO claimed it "disrupted their work for around **30 minutes**." Reality: all Pegasus servers went offline for weeks. New infrastructure appeared months later.

Case 1: Ahmed Mansoor — UAE (2016)

The Trigger for Pegasus Discovery

- **Ahmed Mansoor**: Award-winning **human rights activist** in the UAE
- Received suspicious SMS messages with links promising "secrets" about torture in UAE prisons
- Instead of clicking, he **forwarded the messages to Citizen Lab**
- Researchers clicked the link in a controlled environment

What They Found

- **3 zero-day exploits** for Apple iOS 9.3.3
- A full copy of **Pegasus spyware**
- Disclosed to Apple $\rightarrow$ emergency patch released within 10 days

Mansoor had previously been targeted by ***FinFisher*** *and* ***Hacking Team*** *spyware — three different surveillance vendors used against one activist.*

Case 2: Mexico — #GobiernoEspía (2017)

Widespread Abuse

Dozens of Mexican **lawyers, journalists, human rights defenders, opposition politicians, anti-corruption advocates**, and even an **international investigation team** were targeted with Pegasus in 2016.

Key Details:

- At least **3–5 separate Pegasus operators** active in Mexico
- Used **politically themed** domain names (e.g., `animal-politico.com`)
- Sparked the **#GobiernoEspía** ("Government Spying") political scandal
- Led to an ongoing **criminal investigation**
- Even after exposure, **new operators appeared** within months

Lesson

Even public exposure and criminal investigations may not stop surveillance abuse when governments are the perpetrators.

Case 3: Saudi Arabia & Jamal Khashoggi (2018)

Journalism Under Surveillance

- **Jamal Khashoggi**: Saudi journalist and *Washington Post* columnist
- **Murdered** inside the Saudi consulate in Istanbul, October 2018
- An Amnesty International staffer and a Saudi activist abroad were targeted with Pegasus by the **same operator**
- This operator conducted surveillance across the Middle East, Europe, and North America

Human Rights Impact

Saudi Arabia was simultaneously seeking to **execute five nonviolent human rights activists** accused only of chanting slogans at demonstrations and posting protest videos on social media.

Legal Frameworks for Surveillance

International Law

- **UDHR Art. 12**: Right to privacy
- **ICCPR Art. 17**: Protection from arbitrary interference
- **Wassenaar Arrangement**: Export controls on surveillance tech

Bangladesh

- **Constitution Art. 43**: Right to privacy of correspondence
- **ICT Act 2006**: Some provisions on unauthorized access
- **Digital Security Act 2018**: Cybercrime provisions

The Problem

- Most countries **lack specific laws** against government use of spyware
- Surveillance companies exploit **legal gray areas**
- Cross-border operations make **jurisdiction unclear**
- Export controls are **poorly enforced**
- Victims often have **no legal recourse**

Ethical Questions for Software Engineers

1. **Dual-use technology**: The same skills used to build security tools can build surveillance tools. Where is the line?
2. **Employment ethics**: Would you work for a company like NSO Group if offered a high salary?
3. **Zero-day market**: Should security researchers sell vulnerabilities to governments or disclose them to vendors?
4. **Responsible disclosure**: How should researchers handle discovery of surveillance infrastructure?
5. **Corporate responsibility**: Should tech companies (Apple, Google) do more to protect users from state-sponsored attacks?

Due Diligence Failures

NSO Group's Claims

NSO Group claims Pegasus is sold only to "**vetted government agencies**" for "**legitimate law enforcement**" — specifically combating terrorism and serious crime.

Reality

- Sold to countries with **dubious human rights records**
- Used against **journalists, activists, lawyers, and political opponents**
- **Cross-border surveillance** violates sovereignty of other nations
- No meaningful **oversight or accountability** mechanisms
- Contributes to **global cyber insecurity** by stockpiling zero-day exploits

*In November 2021, the US government **blacklisted NSO Group** for acting contrary to foreign policy and national security interests.*

How to Protect Against Sophisticated Spyware

For Individuals

- Keep devices **fully updated** — patches close known exploits
- Enable **Lockdown Mode** (Apple) for high-risk individuals
- Use **strong, unique passwords** and **hardware security keys**
- Be suspicious of **unsolicited links** — even from known contacts
- Regularly **reboot your phone** — some exploits don't survive reboots
- Use **encrypted messaging** (Signal) for sensitive communications

For Software Engineers / Organizations

- Implement **threat modeling** that includes state-level actors
- Use **Mobile Device Management (MDM)** solutions
- Conduct regular **security audits** and penetration testing
- Implement **network monitoring** for suspicious C&C communications

Key Takeaways

1. Cyber espionage is a **silent, persistent threat** — victims may never know
2. The surveillance industry is a **multibillion-dollar market** with minimal regulation
3. **Pegasus** demonstrated that **any smartphone** can be completely compromised
4. Research labs like Citizen Lab play a **critical role** in accountability
5. **Bangladesh** was among the 45 countries with suspected infections
6. Legal frameworks are **lagging behind** surveillance technology
7. As software engineers, you must consider the **ethical implications** of the tools you build

Discussion Questions

1. Should governments be allowed to use tools like Pegasus? Under what constraints?
2. A company offers you a lucrative job developing "**security monitoring software**." During the interview, you realize it's essentially spyware. What do you do?
3. How should the international community regulate the **export of surveillance technology**?
4. You discover that your app has been compromised to **exfiltrate user data** to a government. As the developer, what are your legal and ethical obligations?